

COMPANION DIGITAL PACKAGE

Full Glossary of Identity Terms

275 plain-English definitions from all 22 chapters — sorted A–Z

Every key term used in the book with a complete, exam-ready definition Sourced from IDPro BoK, NIST SP 800-63, and major IAM standards

Mastering Identity Security for CIDPro™
Abbas Kudrati | 2026 Edition

275
Terms

22
Chapters

A–Z
Sorted

100%
Exam-Aligned

Appendix F

Glossary of Key Identity Terms

Plain-English definitions of every key term used in this book — sourced from all 22 chapters
Mastering Identity Security for CIDPro™ • Abbas Kudrati

How to Use This Glossary

This glossary consolidates every key term defined across all 22 chapters of this book. Terms are presented in plain English, with technical precision. Where a term appears in multiple chapters, the most complete definition is given. Cross-references are noted where terms relate closely to one another.

The chapter source column indicates where each term is primarily covered. Where a term appears in multiple chapters (e.g. MFA fatigue, lateral movement, session), only the primary chapter is listed. All 330 practice questions in Appendix A draw on definitions from this glossary.

Terms from the IDPro Body of Knowledge, NIST SP 800-63, and major IAM standards bodies are represented throughout. Where definitions align with an official standard, this is noted in the definition.

Total terms: 275 • Chapters covered: 1–22 • Sorted alphabetically

A

AAL (Authenticator Assurance Level) — A NIST 800-63 measure of authentication strength. AAL1 requires a single factor; AAL2 requires two factors with approved cryptography; AAL3 requires a hardware-bound cryptographic authenticator providing verifier impersonation resistance.

ABAC (Attribute-Based Access Control) — An access control model in which decisions are based on attributes of the user, resource, action, and environment rather than on static role assignments alone. Enables fine-grained, contextual access decisions.

Access certification — A periodic process in which managers or resource owners attest that access held by their team members or users is still appropriate and required. A core IGA control required by SOX, PCI DSS, and ISO 27001.

Access management — The set of processes, policies, and technology ensuring the right people have the right access to the right resources at the right time, with consistent enforcement and auditability.

Access review — A structured process in which authorised reviewers confirm that each person's access remains appropriate for their current role. Synonymous with access certification.

Account recovery — The process of restoring a customer's access to their account when they cannot authenticate using their primary credentials. A high-risk support operation requiring robust identity verification.

Account takeover (ATO) — The state in which an attacker has obtained control of a legitimate user's account and can act as that user. The most common outcome of credential-based attacks.

AES (Advanced Encryption Standard) — The dominant symmetric encryption algorithm. AES-256 is the standard for encrypting data at rest in identity systems.

Agentic AI — An AI system that operates autonomously, interpreting instructions, developing multi-step plans, accessing resources, and executing operations without constant human oversight. Agentic AI systems are non-human identities requiring governance.

AiTM (Adversary-in-the-Middle) — A phishing technique in which the attacker operates a reverse proxy between the victim and the legitimate site, capturing credentials and session cookies in real time. Bypasses TOTP-based MFA; defeated only by FIDO2 phishing-resistant MFA.

Applicant — A subject undergoing the identity proofing process who has submitted a claimed identity but has not yet been verified by the CSP.

APEX — AI-Powered Exposure eXchange. A five-pillar framework for operating identity security in the AI-speed threat era: Assume Compromise, Prioritise Continuously, Eliminate Implicit Trust, eXchange Intelligence, Elevate Offensively.

APPs (Australian Privacy Principles) — The thirteen principles governing how Australian Government agencies and private sector organisations handle personal information under the Privacy Act 1988.

Article 25 (GDPR) — The Data Protection by Design and Default obligation. Requires privacy-protective design choices to be made from the architecture phase, not retrofitted after deployment.

Asymmetric cryptography — A cryptographic system using mathematically related key pairs — public and private. What one key encrypts, only the other can decrypt. The foundation of PKI, TLS, digital signatures, and FIDO2.

Attack surface — The full set of all points in a system where an attacker could attempt to enter, extract data, or disrupt operation. Threat modelling systematically maps and reduces attack surfaces.

Attestation — The formal act of a reviewer confirming that access is appropriate and should be retained. In IGA platforms, attestation campaigns are structured access review programmes with workflow and audit evidence capture.

Attribute — A piece of information associated with a digital identity — for example, name, email address, job title, department, or clearance level. Attributes are the building blocks of authorisation decisions.

Attribute release policy — A configuration in a federated identity system controlling which user attributes are shared with which Service Provider. Operationalises GDPR data minimisation in federated architectures.

Audit evidence — Documentation demonstrating that a control exists and operated effectively during the audit period. Controls cannot merely be claimed in an audit — they must be evidenced.

Authentication — The process of verifying that a claimant is genuinely the identity they claim to be. Authentication answers the question: 'Is this person who they say they are?'

Authentication factor — A category of evidence used in authentication: something you know (password, PIN), something you have (hardware key, phone), or something you are (biometric).

Authenticator — A specific implementation of an authentication factor — for example, a password, a TOTP app, a hardware security key, or a biometric. Multiple authenticators may be bound to a single identity.

Authorisation — The process of determining what a verified identity is permitted to access or do within a system. Authentication asks 'who are you?'; authorisation asks 'what are you allowed to do?'

Automated decision-making — Processing personal data to make decisions about individuals solely through automated means, without human involvement. Subject to GDPR Article 22 protections including the right to request human review.

B

Backdoor account — A hidden account created by an attacker to maintain persistent access after the initial compromise, surviving credential rotations and lockouts of the originally compromised account.

bcrypt — A password hashing algorithm designed to be deliberately slow and computationally expensive, with built-in salting. Recommended for password storage in modern identity systems.

Bearer token — An OAuth 2.0 access token whose possession alone is sufficient to access the protected resource. Any entity holding the token can use it, making secure transmission and storage critical.

Binding — The process of associating a verified identity with one or more authenticators, creating a durable link for future authentication. Proofing establishes who someone is; binding determines how they prove it repeatedly.

Biometric data — Personal data resulting from specific technical processing of physical, physiological, or behavioural characteristics allowing unique identification of a natural person. Special category data under GDPR Article 9.

Break-glass account — An emergency high-privilege account that bypasses normal authentication controls, used only when standard authentication is broken. Must be monitored continuously and audited rigorously.

Brute force — An attack that systematically attempts many passwords against a specific account. Mitigated by account lockout, rate limiting, and MFA.

C

CA (Certificate Authority) — A trusted entity that issues and digitally signs X.509 certificates, binding public keys to verified identities. The root of trust in a PKI.

CAEP (Continuous Access Evaluation Profile) — An OpenID Foundation specification enabling real-time security event types so that IdPs and applications can share session state signals and trigger near-instant session revocation without waiting for token expiry.

CCPA / CPRA — California Consumer Privacy Act / California Privacy Rights Act. US state law granting California residents privacy rights including access, deletion, correction, and opt-out of sale of personal data.

Centralised identity — An identity architecture in which a single authority (such as an enterprise Active Directory or a national identity scheme) is the single source of truth for all identity records.

Certificate Revocation List (CRL) — A list published by a CA of certificates that have been revoked before their expiry date. Checked by systems verifying certificate validity.

CIAM (Customer Identity and Access Management) — The discipline of managing the identities of an organisation's customers — people who access products and services from outside the firewall. Focuses on large scale, user experience, privacy, and fraud prevention.

Claimant — A subject who presents credentials for authentication; what a subscriber becomes at the point of logging in. The claimant role is performed repeatedly after the subscriber relationship is established once at proofing.

Claimed identity — An applicant's declaration of personal attributes submitted to a CSP. Unverified at the point of submission.

CNAPP (Cloud-Native Application Protection Platform) — A security platform for multi-cloud environments providing attack path visibility, workload protection, and cloud security posture management.

Collective defence — A model of security cooperation in which organisations share threat intelligence pre-competitively within a sector to enable detection and response that exceeds what any single organisation could achieve alone.

Compensating control — A security control that provides equivalent protection where a primary control cannot be implemented. Required when SoD exceptions are formally approved.

Compliance drift — The gradual divergence between required compliance posture and actual state, often occurring between point-in-time audits. Continuous compliance monitoring is designed to detect and remediate drift in real time.

Conditional Access — A Microsoft Entra ID policy engine that evaluates authentication requests against defined conditions — location, device compliance, risk level, user group — and enforces access controls in real time.

Consent — Freely given, specific, informed, and unambiguous indication of agreement to the processing of personal data. Under GDPR, consent must be as easy to withdraw as it is to give.

Continuous access evaluation — A session management technique in which access decisions are re-evaluated in near-real-time based on changing risk signals, enabling sessions to be revoked before token expiry.

Continuous compliance — The approach that shifts from periodic audit verification to real-time monitoring and automated remediation of compliance posture, reducing the window between control failure and detection.

Continuous threat modelling — The integration of threat analysis into regular engineering and operations rhythms rather than as a one-time exercise at project inception.

Control-based compliance — The approach that implements specific enumerated controls mapped to regulatory frameworks such as NIST 800-53, CIS Controls v8, or ISO 27001 Annex A.

Conversion rate — In CIAM, the percentage of site visitors who complete registration and become active users. A primary metric of identity user experience effectiveness.

Credential — An object or data structure that authoritatively binds an identity to one or more authenticators possessed by the subscriber.

Credential Service Provider (CSP) — A trusted entity that conducts identity proofing and issues credentials to subscribers.

Credential stuffing — An automated attack that tests username-password pairs obtained from breach databases against live services, exploiting password reuse. Differs from brute force in generating only one failure per account.

Credential Vault — A hardened, encrypted storage system for privileged passwords and secrets, providing automated rotation, access control, and full audit logging. The core component of a PAM platform.

CRL (Certificate Revocation List) — See Certificate Revocation List.

CTAP (Client to Authenticator Protocol) — The FIDO Alliance protocol governing communication between a client platform and an external FIDO2 authenticator. Current version: CTAP 2.2.

D

DAC (Discretionary Access Control) — An access control model in which the owner of a resource directly controls who can access it. Does not scale to enterprise environments.

Data controller — In GDPR terminology, the entity that determines the purposes and means of processing personal data and bears primary compliance obligations.

Data minimisation — The principle that only personal data necessary for the stated purpose should be collected and processed. A foundational constraint on IAM data model design.

Data Processing Agreement (DPA) — A contract between a data controller and data processor specifying how personal data may be processed, security obligations, and breach notification responsibilities.

Data Protection by Design — The obligation to build privacy protections into systems from the design phase rather than retrofitting them. Required by GDPR Article 25.

Data Protection Impact Assessment (DPIA) — A structured risk assessment of how a proposed processing activity affects individuals' privacy rights. Mandatory for high-risk processing under GDPR Article 35.

Data processor — In GDPR terminology, an entity that processes personal data on behalf of a controller. Identity platform vendors frequently act as data processors.

Data subject — In GDPR terminology, the identifiable individual whose personal data is being processed.

Data Subject Rights — Rights granted to individuals under data protection law: access, rectification, erasure, portability, restriction, and the right to object. Must be technically supported by identity systems.

DCSync — An Active Directory attack technique that uses the directory replication protocol to extract password hashes from domain controllers without having to run code on the DC itself.

Decentralised identity — An identity architecture in which individuals hold and control their own identity claims — typically via a digital wallet — rather than depending on a central identity provider.

Defence in depth — A security architecture principle applying multiple independent controls at different layers so that the failure of one does not leave a threat unmitigated.

Deprovisioning — The process of removing access rights and disabling or deleting accounts when they are no longer required — the 'leaver' stage of the joiner-mover-leaver lifecycle.

DFD (Data Flow Diagram) — A visual representation of a system showing processes, data flows, data stores, external entities, and trust boundaries. The primary structural tool in threat modelling.

DID (Decentralised Identifier) — A W3C standard identifier format that resolves to a DID Document containing public keys and service endpoints, stored on a decentralised registry.

Digital certificate — An X.509 document binding a public key to an identity, signed by a Certificate Authority. Used in TLS, code signing, and smart card authentication.

Digital identity — An electronic representation of an entity — a person, organisation, or device — that enables it to be identified and authenticated in digital systems.

Digital signature — A cryptographic mechanism providing authenticity, integrity, and non-repudiation. Created using a private key and verified using the corresponding public key.

DPoP (Demonstrating Proof of Possession) — IETF RFC 9449 extension to OAuth that makes access tokens sender-constrained by binding them to the client's private key, defeating token replay attacks.

DREAD — A risk scoring model quantifying threat severity across five dimensions: Damage, Reproducibility, Exploitability, Affected users, Discoverability.

Dwell time — The duration between initial compromise and detection. The 2024 global median was 10 days. Reduced by improved monitoring, lower detection thresholds, and ITDR tooling.

Dynamic KBA — Knowledge-based authentication using real-time or transaction-based data, as opposed to static personal facts. More resistant to breach data than static KBA but still limited.

E

ECC (Elliptic Curve Cryptography) — An asymmetric cryptographic system providing equivalent security to RSA at smaller key sizes. Preferred for mobile, IoT, and constrained environments.

eIDAS — EU Regulation establishing the legal framework for electronic identification and trust services. eIDAS 2.0 introduces the European Digital Identity Wallet.

eKYC (Electronic Know Your Customer) — The digital equivalent of the traditional KYC process, allowing identity verification to be completed remotely via digital channels.

Entra Connect — Microsoft's directory synchronisation tool, synchronising on-premises Active Directory identities and attributes to Microsoft Entra ID.

Entra ID Identity Protection — Microsoft's machine-learning-based service generating risk signals for sign-ins and users, integrated with Conditional Access for real-time policy enforcement.

Entitlement — A specific permission or privilege granted to an identity, allowing it to perform an action on a resource. Entitlements are managed by IGA platforms.

EU AI Act — Regulation 2024/1689. A risk-based framework for AI systems in the EU, effective 1 August 2024. Prohibits certain AI practices and classifies high-risk AI systems — including some identity-related AI.

External entity — In a threat modelling DFD, an actor or system outside the scope boundary that interacts with the system being modelled. External entities are untrusted by default.

F

FAL (Federated Assurance Level) — A NIST 800-63 measure of the strength of the assertion protocol in a federated architecture. FAL1 permits signed bearer assertions; FAL2 requires encryption; FAL3 requires the subscriber to prove key possession.

FAPI (Financial-grade API) — An OpenID Foundation security profile of OAuth 2.0 and OIDC for high-value financial API access. Requires PAR, sender-constrained tokens, and mTLS.

FedRAMP — US Federal Risk and Authorisation Management Program, standardising security assessment for cloud services used by federal agencies.

Federation — An architecture enabling users from one identity domain to access resources in another domain using their existing credentials, based on a pre-established trust relationship.

FIDO Alliance — Industry consortium governing FIDO2, CTAP, WebAuthn (in collaboration with W3C), and passkey specifications for phishing-resistant authentication.

FIDO2 — The FIDO Alliance's overarching standard for passwordless, phishing-resistant authentication. Comprises WebAuthn (W3C) + CTAP (FIDO Alliance).

Fractured identity — A situation in which a single customer has multiple disparate identity records in the same system, typically caused by multiple registration pathways or unlinked social login identities.

G

GDPR (General Data Protection Regulation) — EU Regulation 2016/679. The global baseline for data protection obligations, effective May 2018. Applies extraterritorially to any organisation processing EU residents' personal data.

Geo-distributed authentication — Deploying authentication services across multiple geographic regions to minimise latency and maximise availability for globally distributed users.

Golden Ticket — An Active Directory attack in which an attacker with the KRBTGT account hash forges Kerberos Ticket Granting Tickets for any domain user with any privilege level.

Graceful degradation — The ability of an authentication system to continue providing some level of service — alternative methods, fallback flows — when a primary component is unavailable.

H

Hardcoded credential — A credential embedded directly in source code, configuration files, or scripts rather than managed through a secrets management system. A leading source of non-human identity exposure.

Hardware Security Module (HSM) — Tamper-resistant hardware that stores cryptographic keys and performs cryptographic operations without exposing key material. Required for high-assurance key management.

Hashing — A one-way function converting input data of any size into a fixed-length digest. Used for password storage and data integrity verification. Cannot be reversed.

HIPAA — US Health Insurance Portability and Accountability Act. Applies to covered entities and business associates handling Protected Health Information.

IAL (Identity Assurance Level) — A NIST 800-63 measure of confidence in the strength of the identity proofing process. IAL1 is self-asserted; IAL2 is verified (remote or in-person); IAL3 requires in-person proofing with mandatory biometrics.

Identity — The set of attributes that define and distinguish one entity — a person, organisation, or device — from all others within a context. The foundational concept of the IAM discipline.

Identity as a System — The conceptual model treating identity infrastructure as a continuous, stateful, dynamic, distributed system requiring runtime observability — analogous to how networks require NDR and endpoints require EDR.

Identity attack chain — The sequential progression of an identity-based attack: reconnaissance, initial access, privilege escalation, lateral movement, persistence, and impact.

Identity evidence — Information or documentation submitted by an applicant to support their claimed identity, which may be physical (passport) or digital (verified credential).

Identity fabric — An integrated identity architecture that provides a unified set of identity services across cloud, on-premises, and hybrid environments from a common policy and governance layer.

Identity federation — The linking of a person's electronic identity across multiple distinct identity management systems using standards such as SAML 2.0 or OIDC.

Identity Firewall — A security capability that proactively segments identities during a live incident, blocking a compromised account from authenticating to any system while investigation proceeds.

Identity Governance and Administration (IGA) — Platforms and processes managing identity governance at scale — access reviews, role management, SoD enforcement, policy compliance, and audit evidence generation.

Identity proofing — The process by which a CSP collects, validates, and verifies information about a person to establish that a claimed digital identity corresponds to a real, legitimate individual.

Identity Provider (IdP) — The entity that manages authentication credentials and issues assertions or tokens to Relying Parties on behalf of authenticated users.

Identity Security Posture Management (ISPM) — An emerging category of tools continuously assessing identity infrastructure configuration and usage against security and compliance benchmarks.

Identity system — The complete set of technology, processes, policies, and people that together manage digital identities — from creation through to deletion.

IDOR (Insecure Direct Object Reference) — A web vulnerability in which an application uses user-supplied identifiers to reference objects without authorisation checks, enabling horizontal privilege escalation.

IDEAL Framework — Silverfort's five-pillar operating model for enterprise identity security: Integrate, Discover, Enforce, Act, Lightweight.

IETF (Internet Engineering Task Force) — Standards body that produces RFCs for internet standards. Governs OAuth 2.0/2.1, JWT, SCIM, DPoP, PKCE, and other core web identity protocols.

Impersonation — In a customer service context, when an agent logs into a system as if they were the customer they are assisting, bypassing purpose-built agent tooling and removing the audit trail.

Impossible travel — A detection signal in which a single user authenticates from two geographically distant locations within a time window that is physically impossible. A high-confidence account compromise indicator.

In-person proofing — Identity verification conducted with the applicant physically present before a CSP representative. Required for IAL3.

Information disclosure — The STRIDE category covering threats where sensitive data is exposed to unauthorised parties — tokens in logs, verbose error messages, insecure credential storage.

Infostealer — Malware designed to silently harvest credentials, session cookies, and other sensitive data from infected systems.

ITDR (Identity Threat Detection and Response) — A category of security tooling specifically designed to detect identity-based attacks including credential theft, lateral movement, privilege escalation, and impossible travel.

IVIP (Identity Visibility and Intelligence Platform) — An emerging category of security technology providing runtime observability of identity behaviour, filling the gap between IAM policy configuration and actual identity activity.

J

JIT (Just-in-Time) access — An access pattern in which elevated permissions are granted temporarily on demand for a specific purpose, with automatic expiry rather than being permanently assigned.

JWT (JSON Web Token) — IETF RFC 7519 compact, URL-safe token format consisting of Base64URL-encoded header, payload, and cryptographic signature. Used for ID tokens and access tokens in OIDC and OAuth 2.0.

K

KBA (Knowledge-Based Authentication) — A method of verifying identity through questions based on personal information. Static KBA is no longer considered sufficient above IAL1 due to widespread breach data exposure.

Kerberoasting — An attack technique targeting service accounts with Service Principal Names (SPNs). An attacker requests Kerberos TGS tickets and cracks them offline to recover service account passwords.

KRBtgt account — The Kerberos Key Distribution Center service account in Active Directory. Its password hash signs all Kerberos TGTs; compromising it enables Golden Ticket attacks.

L

LAPS (Local Administrator Password Solution) — Microsoft's tool for automatically managing and rotating unique local administrator passwords on domain-joined computers, preventing Pass-the-Hash lateral movement.

Lateral movement — The process by which an attacker moves through a network or environment after initial access, using compromised credentials to reach additional systems.

Lawful basis — One of six grounds in GDPR Article 6 that must exist before personal data can be processed. Must be identified and documented before processing begins.

LDAP (Lightweight Directory Access Protocol) — IETF RFC 4510 protocol for querying and managing directory services. The foundational protocol for enterprise directory environments.

Least privilege — The principle that every identity should have access only to the minimum permissions required to perform their function — and no more.

Legitimate interests — A flexible GDPR lawful basis for processing personal data requiring a balancing test between the controller's interests and the individual's rights.

Lightweight deployment — The fifth pillar of the IDEAL Framework. Identity security platforms must integrate with existing IAM infrastructure without requiring changes, agents, or added operational complexity.

Liveness detection — A technique used in remote biometric proofing to confirm that the biometric sample is from a live person in real time, not a static image or video.

Login success rate — The percentage of authentication attempts that succeed on the first try. A primary metric of both user experience quality and security posture.

M

MAU (Monthly Active Users) — The number of unique users who authenticate and interact with a service within a calendar month. A primary CIAM adoption metric.

MFA (Multi-Factor Authentication) — Authentication using two or more factors from different categories — something you know, something you have, something you are.

MFA adoption rate — The percentage of registered users who have enrolled in multi-factor authentication.

MFA fatigue attack — An attack overwhelming a user with repeated push authentication requests until they approve one to make the notifications stop. Also called prompt bombing. Mitigated by number matching.

Mimikatz — A publicly available post-exploitation tool capable of extracting plaintext passwords, NTLM hashes, Kerberos tickets, and other credential material from Windows system memory.

Minimum necessary collection — The privacy principle that only the identity attributes genuinely required for a transaction should be collected during proofing. Over-collection creates privacy risk without security benefit.

MITRE ATT&CK — A publicly available knowledge base of adversary tactics, techniques, and common knowledge. Includes identity-specific techniques across Credential Access, Privilege Escalation, and Persistence tactics.

mTLS (Mutual TLS) — An extension of TLS where both client and server authenticate each other using certificates. Used in zero-trust service-to-service and workload authentication.

MTTR (Mean Time to Respond) — The average time from alert creation to containment action. SOAR automation dramatically reduces MTTR for identity-related incidents.

Mythos Preview — An AI system (Claude Mythos Preview) that demonstrated the ability to identify thousands of zero-day vulnerabilities at unprecedented speed, representing the category of AI-speed offensive capability that the APEX framework addresses.

N

NDB (Notifiable Data Breaches) scheme — Australia's mandatory data breach notification scheme requiring notification of eligible breaches to the OAIC and affected individuals.

NHI (Non-Human Identity) — An identity belonging to a non-person entity: service accounts, API keys, OAuth tokens, managed identities, IoT devices, CI/CD pipeline credentials, or AI agents.

NIST SP 800-63-4 — The final (July 2025) version of NIST's Digital Identity Guidelines. Introduces the risk-based DIRM framework, formally recognises synced passkeys as AAL2, and endorses digital identity wallets.

Non-repudiation — The property that a signer cannot credibly deny having created a digital signature, because only their private key could have produced it.

Number matching — An MFA control requiring the user to match a code displayed in the authentication request to a code shown in their push notification, defeating MFA fatigue attacks.

O

OASIS — Organisation for the Advancement of Structured Information Standards. Governs SAML 2.0 and XACML.

OAuth 2.0 — IETF RFC 6749 authorisation framework enabling delegated API access. Does not perform authentication — that requires OIDC built on top of OAuth 2.0.

OAuth 2.1 — IETF draft specification consolidating OAuth 2.0 best practices: PKCE mandatory, Implicit and ROPC grants removed, bearer tokens prohibited in query strings.

Observability — The ability to understand the internal state of a system from its external outputs. Applied to identity: the ability to understand what identities are doing in real time from authentication events and behavioural signals.

OCSP (Online Certificate Status Protocol) — A protocol for real-time certificate revocation checking, as an alternative to downloading a full CRL.

OIDC (OpenID Connect) — An authentication protocol built on OAuth 2.0. Adds the ID token — a signed JWT containing identity claims — enabling SSO and federated authentication.

OpenID Foundation — Non-profit governing OpenID Connect, CAEP, SSF, FAPI, and OpenID for Verifiable Credentials.

Orphaned account — An account that remains active after the associated identity no longer requires access — typically because deprovisioning was missed, delayed, or never implemented.

Orphaned Privileged Account — A privileged account that exists without an active, legitimate owner — a high-risk configuration frequently exploited in PAM attacks.

P

Partner identity — The identity of an external partner, supplier, or collaborator accessing an organisation's resources. Managed through B2B federation and partner IAM programmes.

Pass-the-Hash (PtH) — A lateral movement technique in Windows environments in which an attacker uses a captured NTLM hash to authenticate to systems without knowing the plaintext password.

Passkey — A FIDO2 discoverable credential designed for consumer deployment. Synced passkeys qualify as AAL2 under NIST SP 800-63-4; device-bound passkeys qualify as AAL3.

Password spray — An attack testing a small number of commonly used passwords against a large number of accounts, designed to avoid triggering account lockout thresholds.

Passwordless authentication — Authentication without a password, using phishing-resistant mechanisms such as FIDO2, device biometrics, or hardware keys.

PAW (Privileged Access Workstation) — A dedicated, hardened device used exclusively for privileged administrative tasks, never for general-purpose activities such as email or web browsing.

PBAC (Policy-Based Access Control) — An access control model expressing access decisions as formal structured policies evaluated by a policy engine, combining attributes and contextual logic.

PBKDF2 (Password-Based Key Derivation Function 2) — A NIST-recommended password hashing algorithm with configurable iteration count. Used for password storage where bcrypt is not available.

PCI DSS — Payment Card Industry Data Security Standard. Applies to all organisations processing, storing, or transmitting cardholder data.

PDPA (Singapore) — Personal Data Protection Act. Singapore's primary privacy legislation governing private sector data processing.

Persistence — Post-compromise techniques used by attackers to maintain access even if the initially compromised credential is rotated or revoked — including enrolling new MFA devices and creating backdoor accounts.

Personal data — Any information relating to an identified or identifiable natural person.

Phishing — A social engineering attack deceiving users into disclosing credentials or approving authentication requests through fraudulent communications or websites.

Phishing-resistant MFA — MFA that cannot be defeated by a real-time phishing attack because its credential response is cryptographically bound to the legitimate domain. FIDO2 is the primary phishing-resistant MFA standard.

PKI (Public Key Infrastructure) — The system of standards and technologies supporting secure management and exchange of public keys through digital certificates and Certificate Authorities.

PKCE (Proof Key for Code Exchange) — RFC 7636. An OAuth extension preventing authorisation code interception attacks. Mandatory in OAuth 2.1 for all clients.

Point-in-time audit — A traditional compliance audit evaluating whether controls were in place at a specific moment or over a defined period. Contrasted with continuous compliance monitoring.

Post-change notification — Sending an alert to all previously validated contact channels when any credential or contact information is updated, enabling genuine customers to detect and reverse unauthorised changes.

Preassembled User Activity Timeline — An automatically compiled chronological record of all authentication events for an identity across all protocols and resources, enabling rapid incident investigation.

Presentation attack — An attempt to defeat a biometric system by using a photograph, video, or mask of the real person rather than the person themselves.

Principal — An entity — human or non-human — that can be authenticated and authorised within an identity system.

Privacy by Default — The principle that the most privacy-protective settings must be applied automatically, without the individual taking any action. Required by GDPR Article 25.

Privacy by Design — The approach of embedding privacy protections into the design of a system from the outset rather than adding them retrospectively. Required by GDPR Article 25.

Privilege escalation — Obtaining access rights beyond what was authorised. Vertical escalation means gaining higher privilege; horizontal escalation means accessing the same level of privilege belonging to a different account.

Privileged Access Management (PAM) — The security framework, practices, and tools for controlling, monitoring, and auditing privileged access across an environment.

Progressive profiling — Collecting personal attributes gradually through natural engagement rather than requiring full profile completion at registration. A CIAM and privacy-by-design technique.

Prompt injection — An attack against agentic AI systems where malicious instructions are embedded in content the agent processes, causing it to take unintended or harmful actions.

Proofing — See Identity proofing.

Provisioning — The process of granting an identity access to systems, applications, and resources required to perform its function — the 'joiner' stage of the JML lifecycle.

Public key — The shareable half of an asymmetric key pair, distributed freely. Used for signature verification and encryption.

Purpose limitation — The GDPR principle prohibiting the use of personal data for purposes materially different from those stated at collection without a new lawful basis.

R

RBAC (Role-Based Access Control) — An access control model in which permissions are bundled into named roles representing job functions, and users are assigned to roles rather than receiving permissions directly.

RBA (Risk-Based Authentication) — An authentication model dynamically adjusting authentication requirements based on real-time risk signals, requiring step-up authentication when risk is elevated.

Re-proofing — A repeated identity proofing event triggered by policy renewal, life event changes, assurance level escalation, or credential compromise.

Relying Party (RP) — An application or service that consumes authentication assertions from a verifier or IdP to make access decisions.

Remote proofing — Identity verification conducted digitally without requiring the applicant to be physically present. Standard for IAL2 workflows using document upload and liveness detection.

Renewable Biometric Reference (RBR) — A mathematical transformation of biometric data that can be 'rotated' if compromised, addressing the irreversibility problem of traditional biometric templates.

Repudiation — The STRIDE category covering threats where an actor can plausibly deny performing an action due to insufficient logging, unsigned transactions, or poor audit controls.

Residual risk — The remaining risk after mitigating controls have been applied. Must be explicitly accepted and documented.

Right of erasure — The right of an individual under GDPR Article 17 to request deletion of personal data where no lawful basis for retention exists.

Right to erasure — See Right of erasure.

Risk register — A documented inventory of identified risks, their assessed severity, the controls applied, and the residual risk. The primary artefact of risk-based compliance.

Risk-based compliance — The approach prioritising controls based on the impact and likelihood of identity risks, allocating stronger controls to higher-risk accounts and resources.

RSA (Rivest-Shamir-Adleman) — The most widely deployed asymmetric encryption algorithm, based on the mathematical difficulty of factoring large prime numbers.

Rubber-stamping — The practice of approving access review items without meaningful review. Produces the appearance of compliance without the substance.

Runtime Access Protection — Silverfort's patented technology for applying security controls inline with authentication requests, without requiring agents or application modifications.

Runtime observability — Monitoring and analysing identity behaviour in real time — who authenticated, from where, to what, using which protocol, with what risk level — as it happens.

S

Salt — A unique random value added to a password before hashing, ensuring identical passwords produce different hashes and defeating rainbow table and lookup attacks.

SAML 2.0 (Security Assertion Markup Language) — OASIS XML-based federation standard for enterprise SSO. The IdP issues signed XML assertions consumed by Service Providers. Widely used for SaaS integration.

SCIM (System for Cross-domain Identity Management) — IETF RFC 7643/7644 RESTful standard for automated user provisioning and deprovisioning across systems when identity events occur in the authoritative source.

Scope — In OAuth 2.0, a string defining the specific subset of a protected resource that a client application is authorised to access.

Secrets management — The practice and tooling for securely storing, rotating, and controlling access to privileged credentials, API keys, and other secret material used by applications and non-human identities.

Separation of Duties (SoD) — An access governance principle ensuring no single identity holds permissions sufficient to complete a sensitive transaction unilaterally, without independent review.

Service account — A non-interactive account used by an application or service to authenticate to other systems. A primary type of non-human identity, frequently over-privileged and under-governed.

Service Provider (SP) — The application or service that delegates authentication to an IdP and consumes the resulting assertion — the relying party in a SAML federation.

Session — A temporary, bounded period of authenticated access established after a successful authentication event, persisting until timeout, revocation, or logout.

Session cookie — A browser-based mechanism storing session state and authentication tokens, enabling SSO across applications within the same domain.

Session hijacking — Stealing a valid authenticated session token and using it to impersonate the legitimate user without re-authenticating.

Session management — The set of controls governing session creation, duration, re-authentication triggers, and termination.

Session recording — The capture of a complete record of a privileged session — all commands, actions, and screen content — for forensic investigation and compliance.

Session revocation — The forced termination of an active session before its natural expiry, triggered by a security event, policy change, or employment termination.

Session timeout — The automatic termination of an inactive session after a defined period, requiring re-authentication to continue.

Shadow AI — AI agents created and deployed outside official IT oversight, without governance, proper permissions management, or monitoring.

Shift left — The principle of moving security activities earlier in the development lifecycle — to design and development phases — when defects are cheapest to fix.

SIEM (Security Information and Event Management) — A platform centralising log data from multiple sources for real-time correlation, threat detection, compliance reporting, and incident investigation.

Silver Ticket — An Active Directory attack in which the attacker forges a Kerberos service ticket for a specific service using the service account's password hash.

SIM swapping — An attack in which an attacker socially engineers a mobile carrier into transferring the victim's phone number to a new SIM, enabling interception of SMS authentication codes.

Single Sign-On (SSO) — An authentication architecture in which a single authentication event with the IdP grants access to multiple connected applications without repeated credential prompts.

SOAR (Security Orchestration, Automation, and Response) — Technology combining security orchestration, automation, and response, enabling automated execution of security playbooks in response to detected threats.

SOC 2 Type I — An audit report assessing the design of controls at a specific point in time.

SOC 2 Type II — An audit report assessing both the design and operating effectiveness of controls over a defined period (minimum six months). More demanding and more credible than Type I.

SoD exception — A documented, approved instance where a user legitimately holds access that would normally constitute a SoD conflict, with compensating controls in place.

SoD rule — A defined conflict between two or more access rights that, if held simultaneously by one person, creates an unacceptable control risk.

SOX (Sarbanes-Oxley Act) — US legislation requiring financial reporting accuracy and internal controls. Drives SoD requirements and access logging obligations for financial systems.

Special category data — A set of personal data types afforded heightened protection under GDPR Article 9: health, genetic, biometric, racial or ethnic origin, political opinions, religious beliefs, trade union membership, sex life or sexual orientation data.

Spear phishing — Targeted phishing directed at a specific individual or organisation, using personalised information to increase credibility and success rates.

SPIFFE/SPIRE — CNCF framework for cryptographic workload identity. SPIFFE defines the SVID credential format; SPIRE is the reference implementation for certificate issuance to workloads.

Spoofing — The STRIDE category covering threats where an entity impersonates another — phishing, IdP impersonation, token forgery, or client application spoofing.

SQL injection — An injection attack in which malicious SQL code is inserted into application queries through unvalidated user input, enabling authentication bypass or data exfiltration.

SSF (Shared Signals Framework) — OpenID Foundation framework for secure, asynchronous delivery of Security Event Tokens between cooperating parties. The transport layer for CAEP.

SSL/TLS — See TLS.

Staged rollout — An identity change management technique deploying changes to a small pilot population first, evaluating results, and progressively expanding deployment to reduce blast radius.

Standing access — Persistent elevated permissions that remain active whether or not the identity is actively performing a privileged task. The risk pattern that JIT access is designed to eliminate.

Step-up authentication — Requiring a stronger authentication level than the current session provides before permitting a high-risk action — such as approving a financial transaction or changing account credentials.

Storage limitation — The GDPR principle requiring personal data to be retained no longer than necessary for the stated purpose.

STRIDE — The Microsoft-developed threat classification framework: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.

Subscriber — A party who has successfully completed identity proofing with a CSP and holds a credential issued by that CSP.

Symmetric encryption — Encryption using the same key for both encryption and decryption. Fast and efficient for data at rest; vulnerable to the key distribution problem.

Synthetic identity fraud — A fraud technique constructing a fictitious identity from a combination of real and fabricated attributes. No single real person is the underlying subject, making it hard to detect via standard cross-referencing.

T

Tampering — The STRIDE category covering threats involving unauthorised modification of data — JWT manipulation, SAML assertion injection, audit log tampering.

Threat modelling — A proactive, structured process for identifying potential security vulnerabilities in a system design, classifying them, and determining mitigations before deployment.

Tiered support model — A structured approach to customer support with self-service (Tier 1), agent-assisted (Tier 2), and specialist/engineering (Tier 3) layers, routing issues to the appropriate level.

TLS (Transport Layer Security) — The cryptographic protocol securing data in transit over the internet. Every HTTPS connection uses TLS. Minimum TLS 1.2 is required; TLS 1.3 is preferred.

Token relay — Using a valid access token to pivot from one service to another — a form of lateral movement in cloud and SaaS environments.

Tokenisation — The replacement of sensitive data with non-sensitive tokens. In identity, OAuth access tokens, refresh tokens, and OIDC ID tokens implement this principle.

Trust boundary — In a threat modelling DFD, a line separating systems or zones with different trust levels. Every data flow crossing a trust boundary requires STRIDE analysis.

Trust Services Criteria — The five criteria evaluated in a SOC 2 audit: Security, Availability, Processing Integrity, Confidentiality, and Privacy.

U

UEBA (User and Entity Behaviour Analytics) — Analytics technology establishing behavioural baselines for users and systems and alerting on deviations that may indicate compromise or insider threat.

V

Vaultless PAM — A PAM approach enforcing security controls at the authentication layer rather than through credential storage, providing immediate broad coverage without requiring account onboarding.

Verifiable Credential (VC) — A W3C standard for cryptographically verifiable digital credentials held and presented by the subject. The building block of decentralised identity architectures.

Verifier — The entity that validates a claimant's credentials at authentication time, checking validity, expiry, and revocation status.

Verifier impersonation resistance — A property of AAL3 authenticators in which the credential response cannot be reused by an attacker who intercepts it, because it is cryptographically bound to the legitimate domain.

Vishing — Voice phishing — social engineering conducted by telephone, frequently targeting help desks to obtain password resets or MFA device registrations.

W

W3C (World Wide Web Consortium) — Governs WebAuthn, DID 1.0, and Verifiable Credentials.

WAM (Web Access Management) — A precursor to modern SSO in which a session cookie was generated after authentication and read by multiple applications within the same perimeter.

WCAG (Web Content Accessibility Guidelines) — W3C guidelines defining accessibility requirements for web content. WCAG 2.1 Level AA is the commonly mandated standard for consumer-facing identity systems.

WebAuthn — The W3C/FIDO Alliance browser API enabling Relying Parties to accept FIDO2 credentials. The client-side half of the FIDO2 standard.

Workforce IAM — The discipline of managing the identities of an organisation's employees, contractors, and internal partners through their full employment lifecycle.

X

X.509 — The ISO standard defining the format of public key certificates used in PKI, TLS, and digital signatures.

Z

Zero Standing Privileges (ZSP) — The principle that no elevated privileges should exist at rest. Permissions are granted only when actively needed and automatically revoked immediately after. The most advanced JIT access model.

Zero Trust — An architectural principle (NIST SP 800-207) stating that no implicit trust should be granted based on network location. Every access request is evaluated individually against identity, device, context, and resource signals.

ZSP coverage rate — The percentage of privileged identities that hold no standing elevated permissions. A primary metric of identity security maturity.

A Note on Terminology

Identity and access management is a field with evolving and sometimes overlapping terminology. Different standards bodies, vendors, and practitioners occasionally use the same term differently. Where definitions in this glossary conflict with vendor documentation, the IDPro Body of Knowledge and NIST SP 800-63 are the authoritative references for CIDPro™ exam purposes.

The CIDPro™ exam tests vendor-neutral conceptual understanding. Vendor-specific terminology (such as Entra-specific or Okta-specific terms) is used in this book for illustration but is not the basis of exam questions. When in doubt, prefer the NIST or IDPro BoK definition.